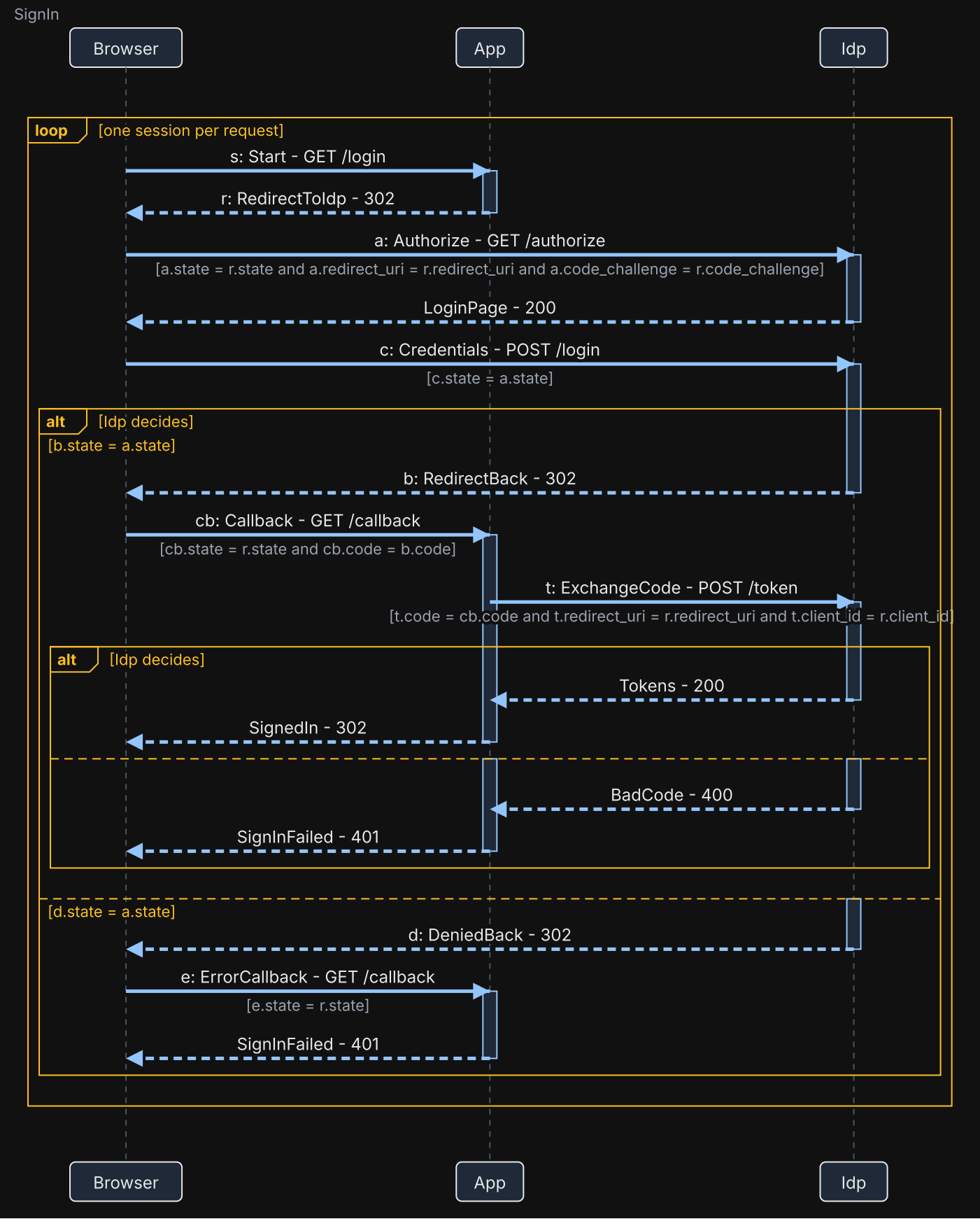

SignIn
Browser
App
Idp
loop
[one session per request]
s: Start - GET /login
r: RedirectToIdp - 302
a: Authorize - GET /authorize
[a.state = r.state and a.redirect_uri = r.redirect_uri and a.code_challenge = r.code_challenge]
LoginPage - 200
c: Credentials - POST /login
[c.state = a.state]
alt
[Idp decides]
[b.state = a.state]
b: RedirectBack - 302
cb: Callback - GET /callback
[cb.state = r.state and cb.code = b.code]
t: ExchangeCode - POST /token
[t.code = cb.code and t.redirect_uri = r.redirect_uri and t.client_id = r.client_id]
alt
[Idp decides]
Tokens - 200
SignedIn - 302
BadCode - 400
SignInFailed - 401
[d.state = a.state]
d: DeniedBack - 302
e: ErrorCallback - GET /callback
[e.state = r.state]
SignInFailed - 401
Browser
App
Idp